

MITRE ATTACKS

Nguyễn Hoàng Khang
Trần Ngọc Bá Duy



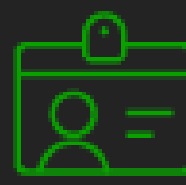
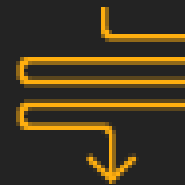
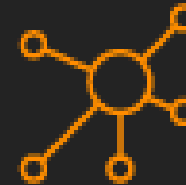
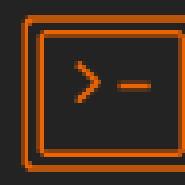
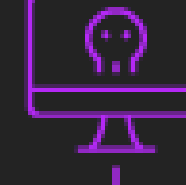
CALDERA

Overview

MITRE
ATT&CK
CON 5.0



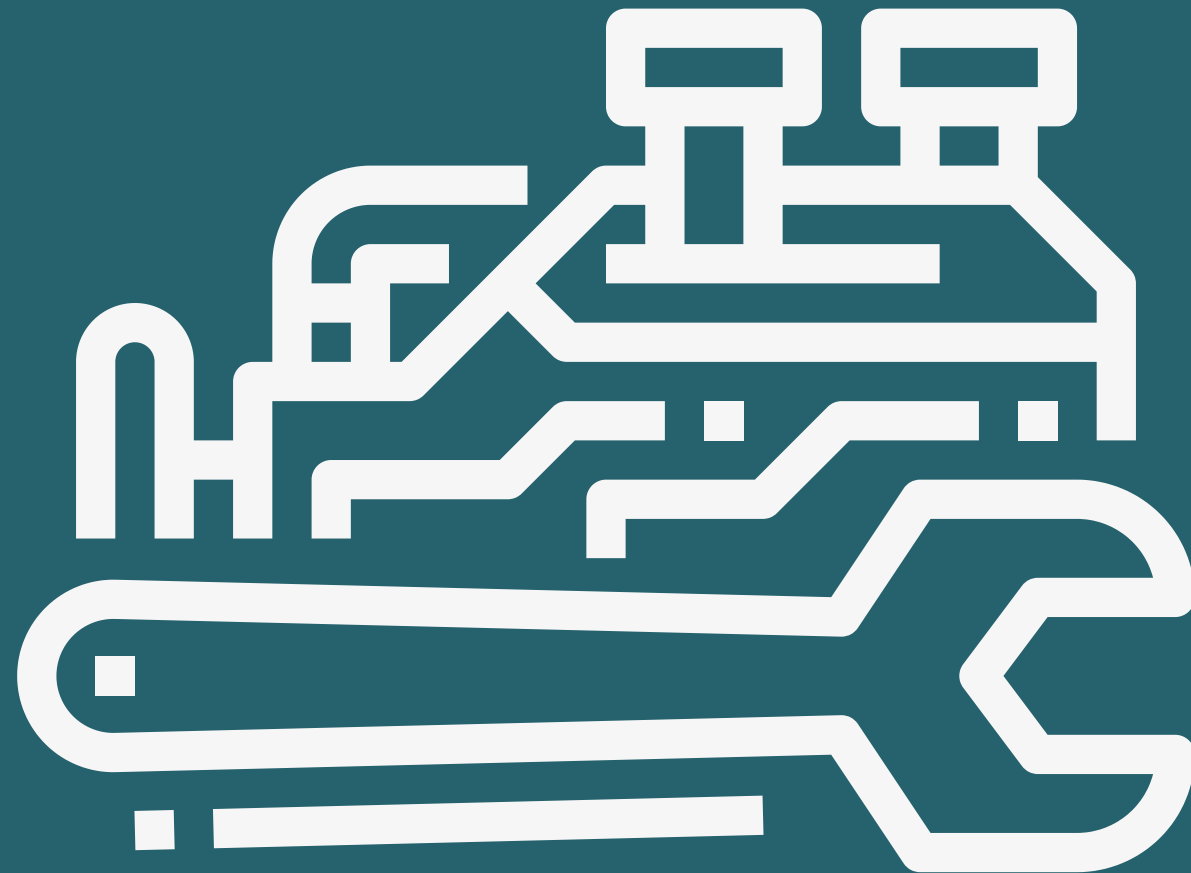
Top Artifacts Used in Each Stage of MITRE Attack Chain

Stages of MITRE Attack											
Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
											
Artifacts											
Remote Services	PowerShell	Cobalt Strike	Mimikatz	PowerShell	Mimikatz	Advanced IP Scanner	RDP	Network Browsing	Cobalt Strike	Rclone	Data Encrypted
Exploits	PsExec	AnyDesk	ProcDump	Rundll32.exe	ProcDump	Netscan	Cobalt Strike	Rclone	PowerShell	WinRAR	Network Breach

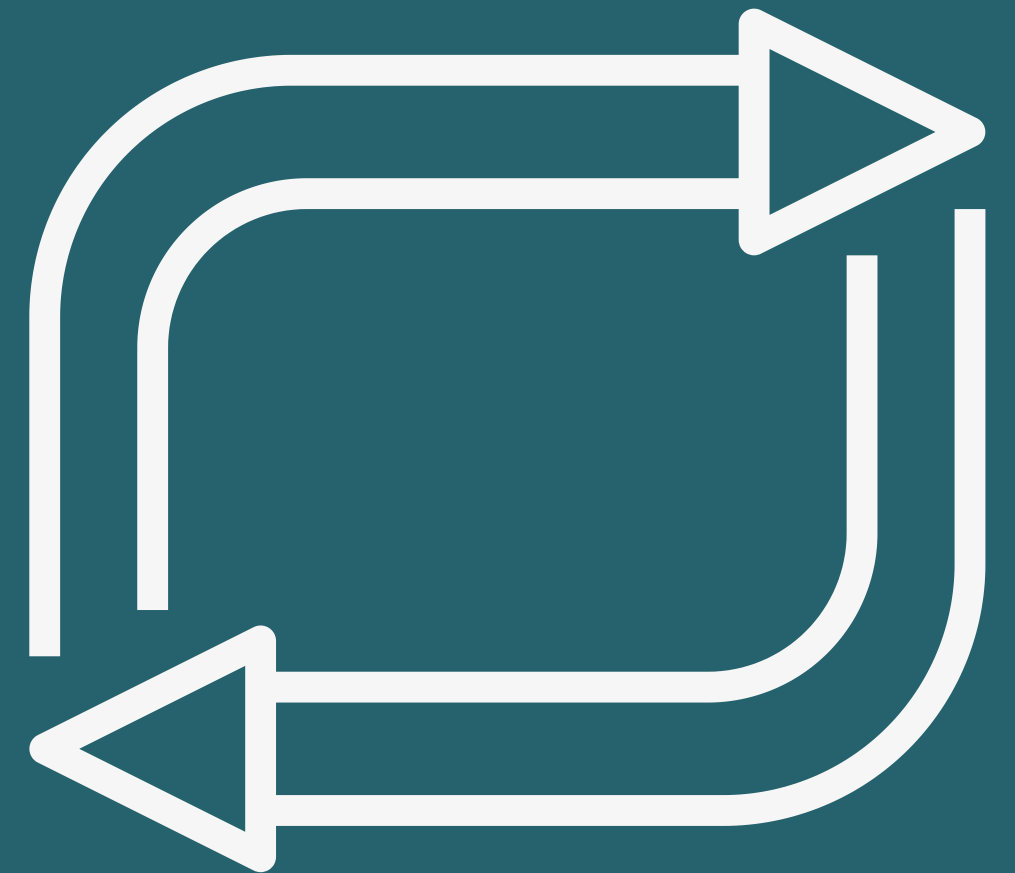
Main cores:



Agent



Ability Engine



Operation Loop

↖ Caldera Utilities

- Large enterprises and government agencies that are high-value targets (finance, energy, defense, healthcare).
- Offer “adversary emulation” or “purple team” services.
- Testing the EDR/XDR/services
- Red/purple teams that are tired of writing custom scripts for every engagement.



Project Goals

Simulate the 4 main techniques of MITRE ATT&CK:

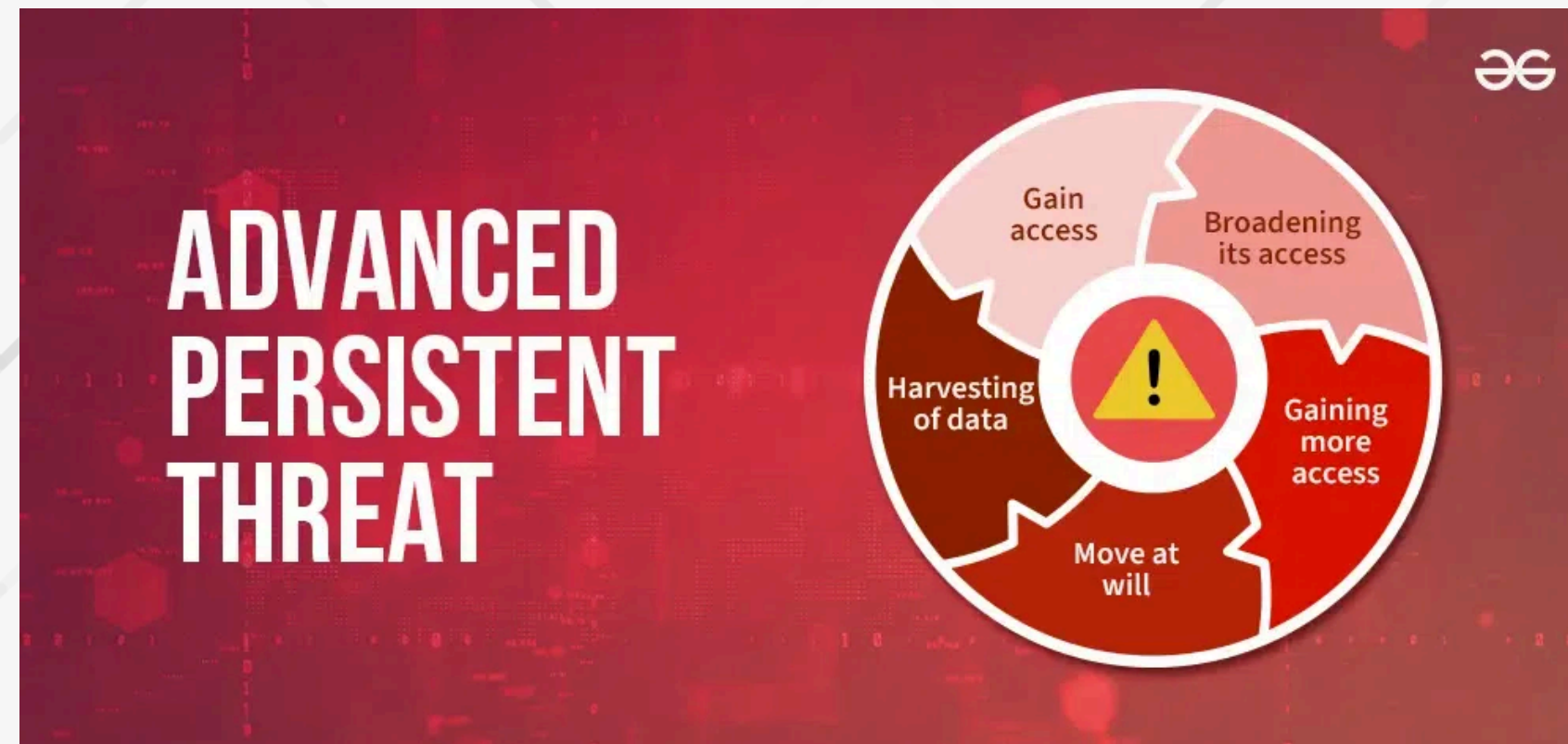
- Initial Access
- C2
- Data Exfiltration
- Lateral Movements (In progress)





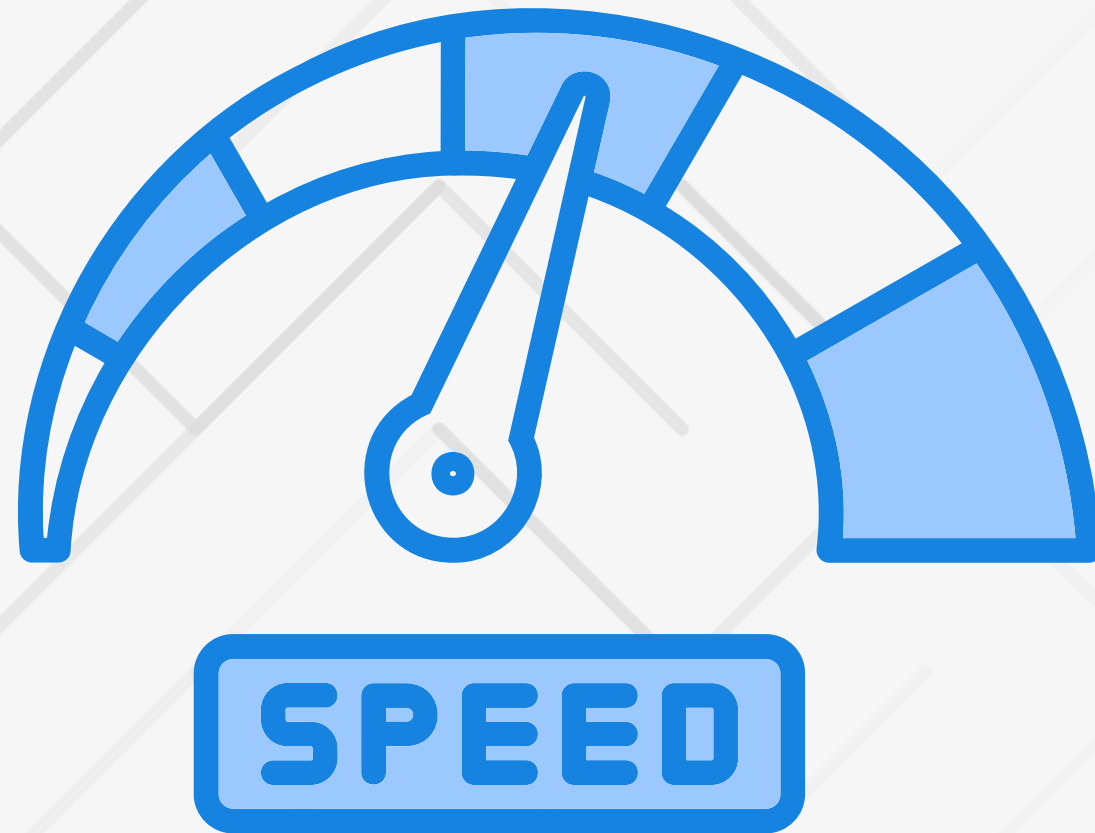
PROBLEMS

↖ Problems



Most defenses have never been tested against real APT or ransomware kill-chains

↖ Problems



**Evolving Threats Outpace
Manual Testing**

↖ Problems

Cybersecurity Skills **Shortage** and Workforce Predictions



The cybersecurity industry has a talent shortage of

4 million professionals.

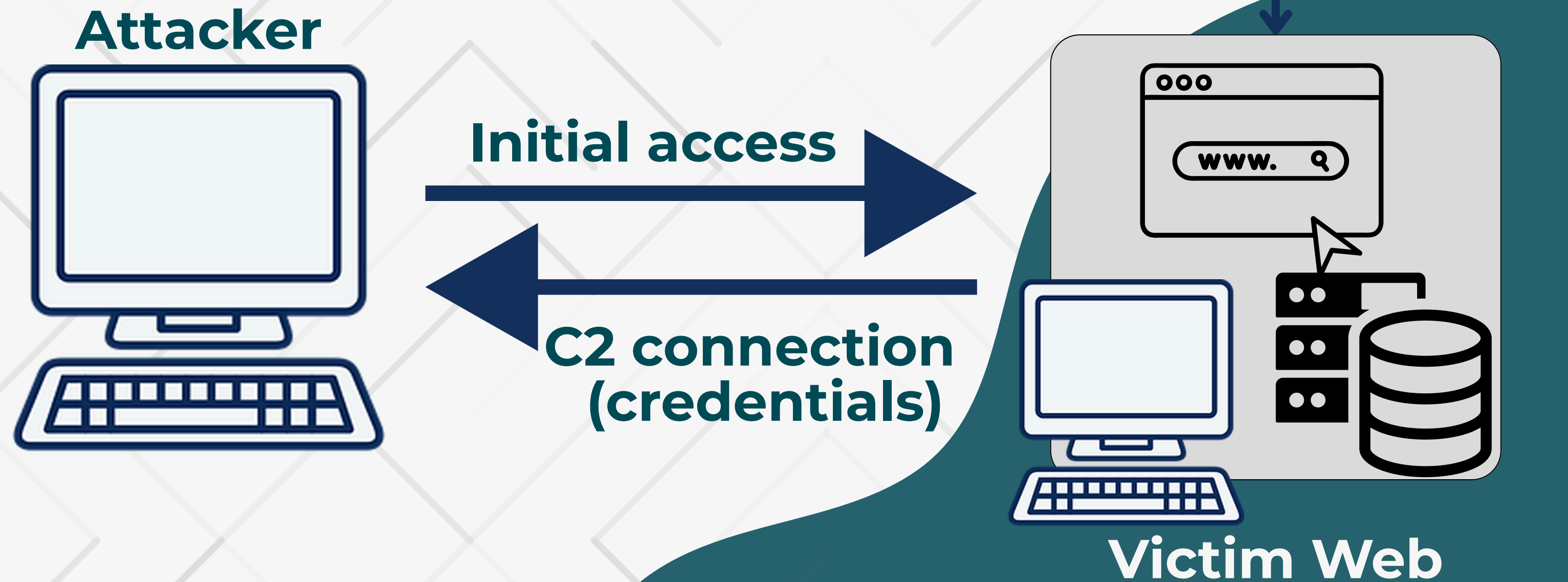
U.S. cybersecurity jobs are expected to grow **33% by 2033.**

4 million global cybersecurity talent shortage



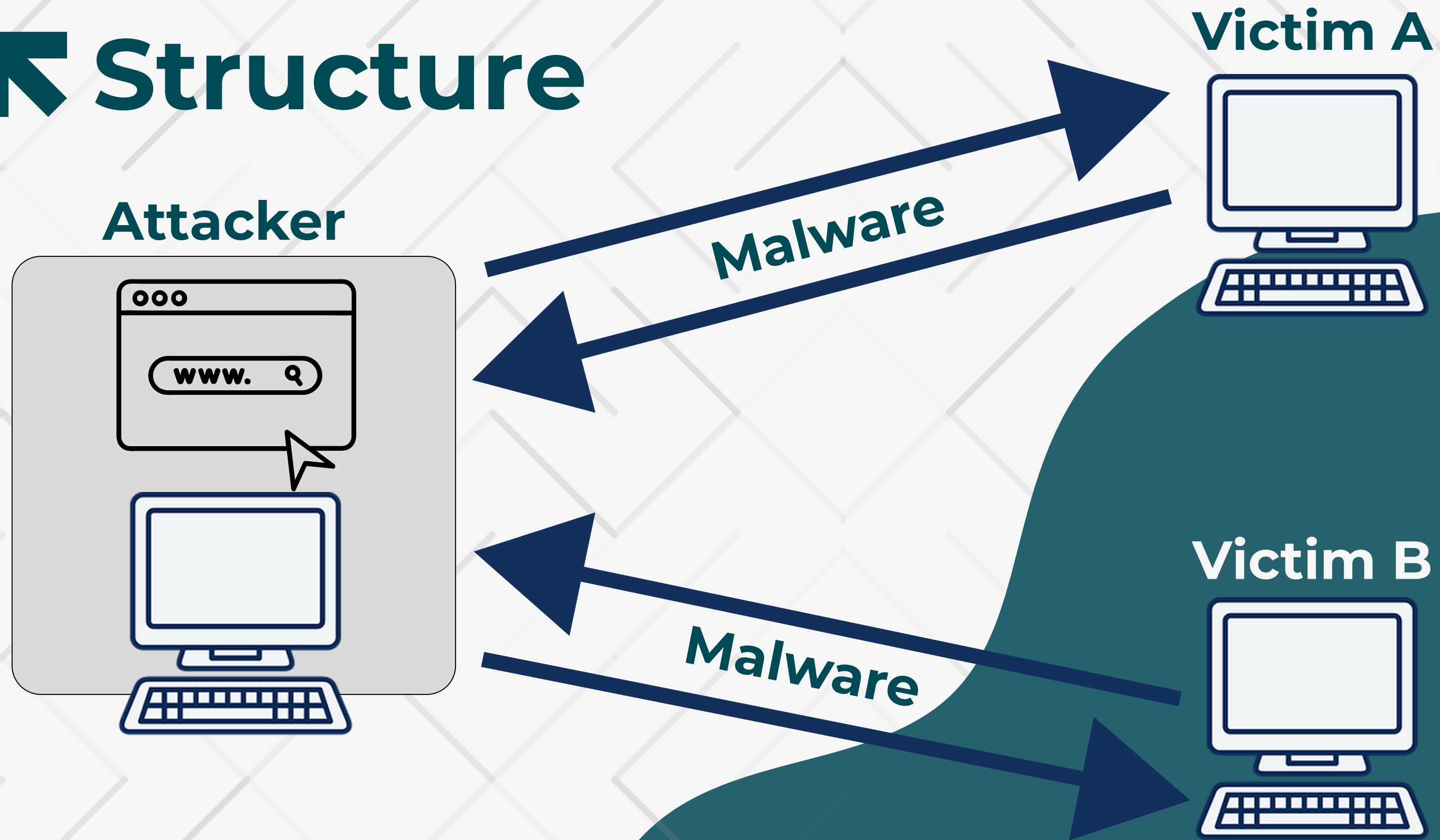
Proposed Structures

Structure



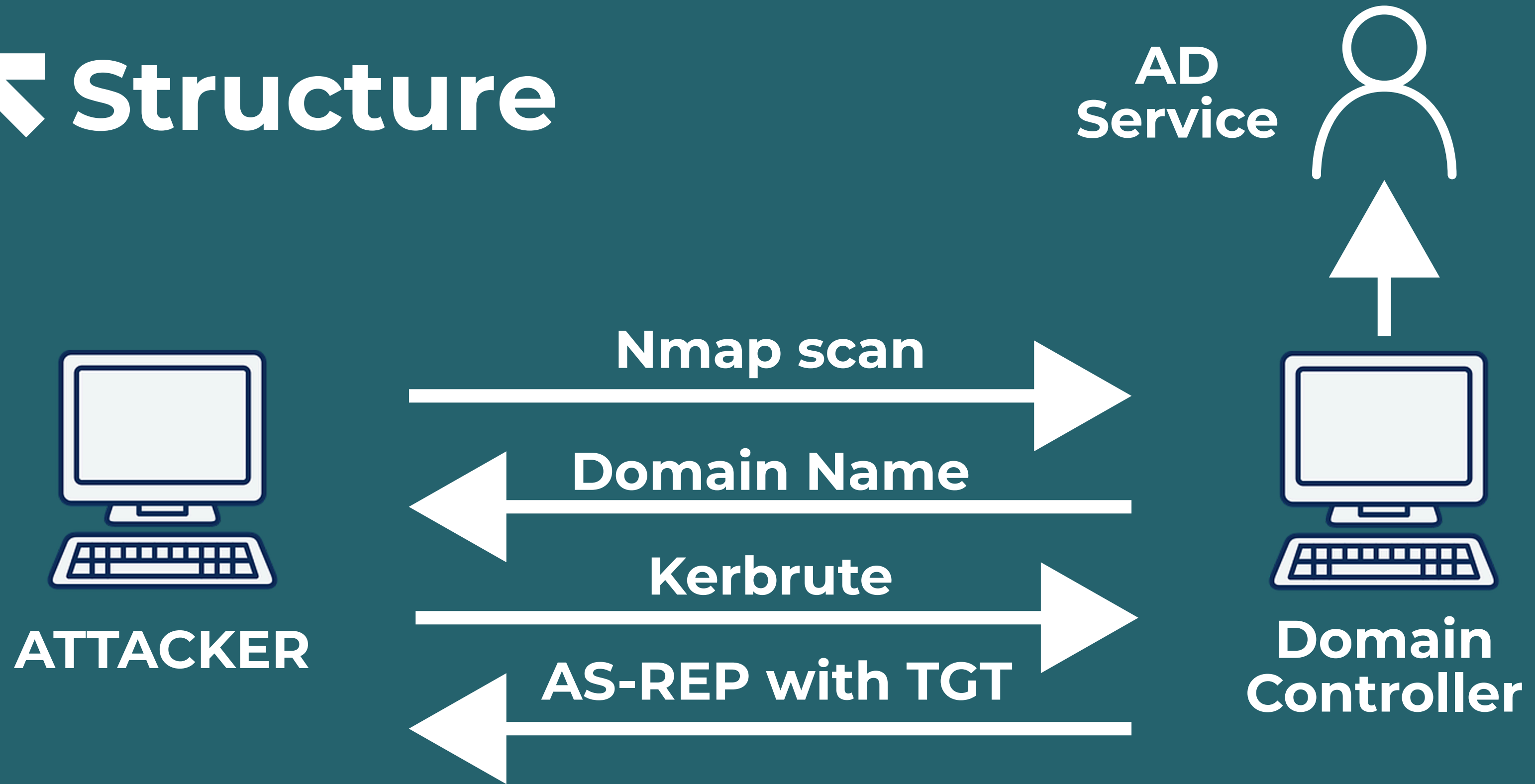
12 **Scenario 1:**

Structure



13 **Scenario 2:**

Structure



14 **Scenario 3:**



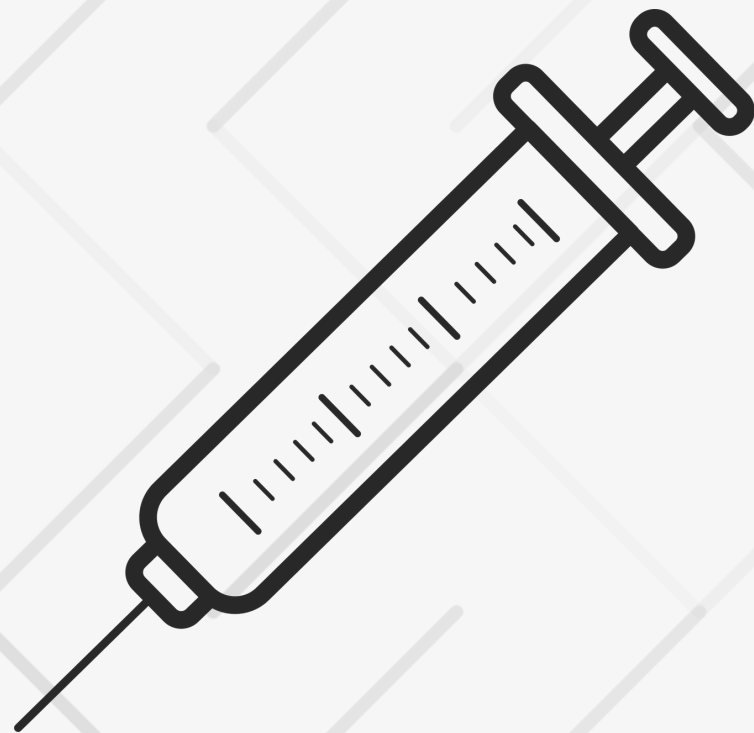


DEPLOYMENT

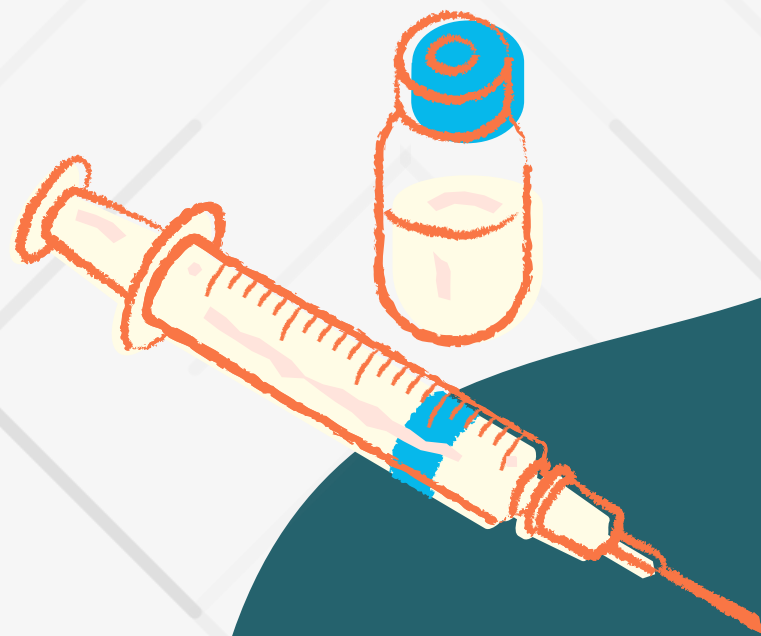
➤ Scenario 1:

**Initial Access
Exploit Public-Facing Application
(ID: T1190)**

Command Injection



XSS



SQLInjection

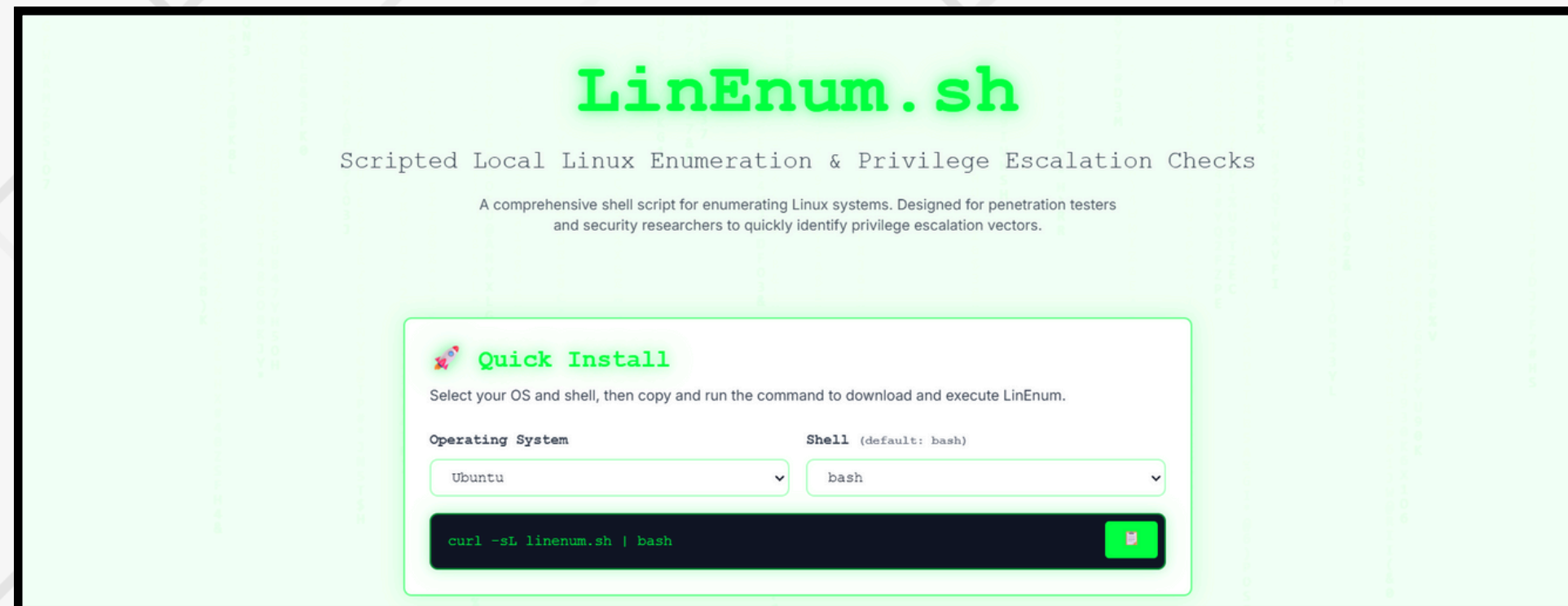


Scenario 1:

Command and Control
Ingress Tool Transfer
(ID: T1105)



Discovery
(TA0007)



LinEnum is
designed to
automate the local
Linux enumeration
and privilege
escalation checks.

Scenario 1:

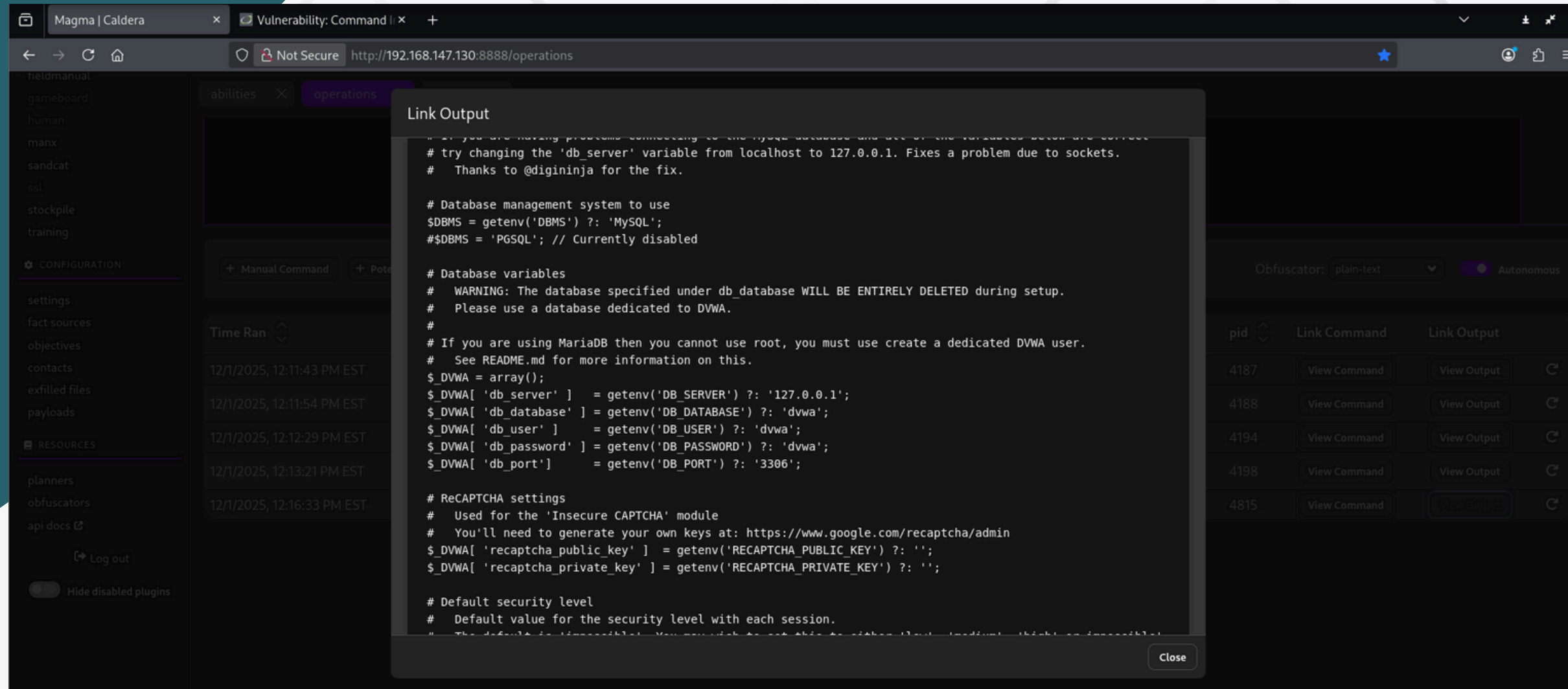
Execution Command and Scripting Interpreter (ID: T1059.004)



Abusing bash/shell to execute the downloaded script, which performs system enumeration.

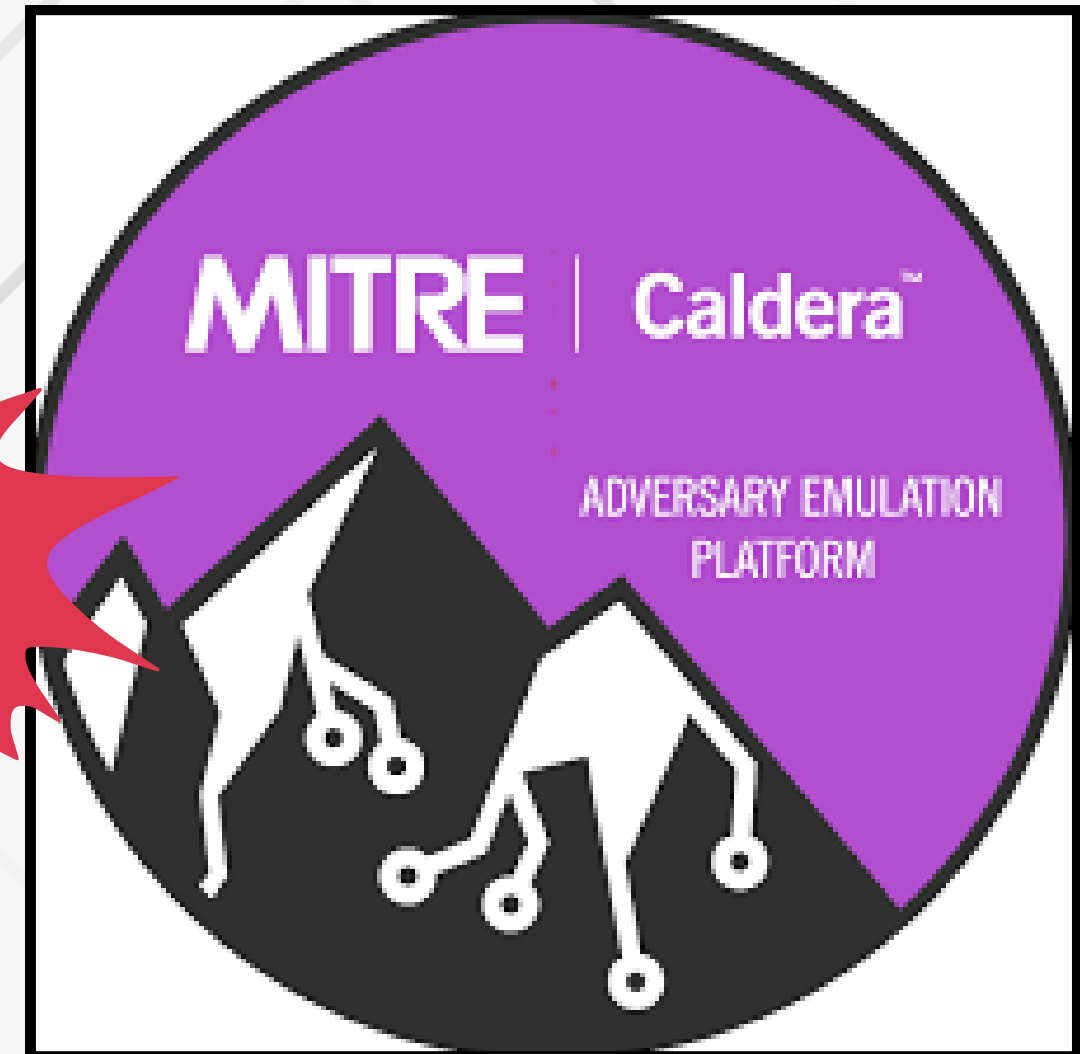
Scenario 1:

Data Exfiltration



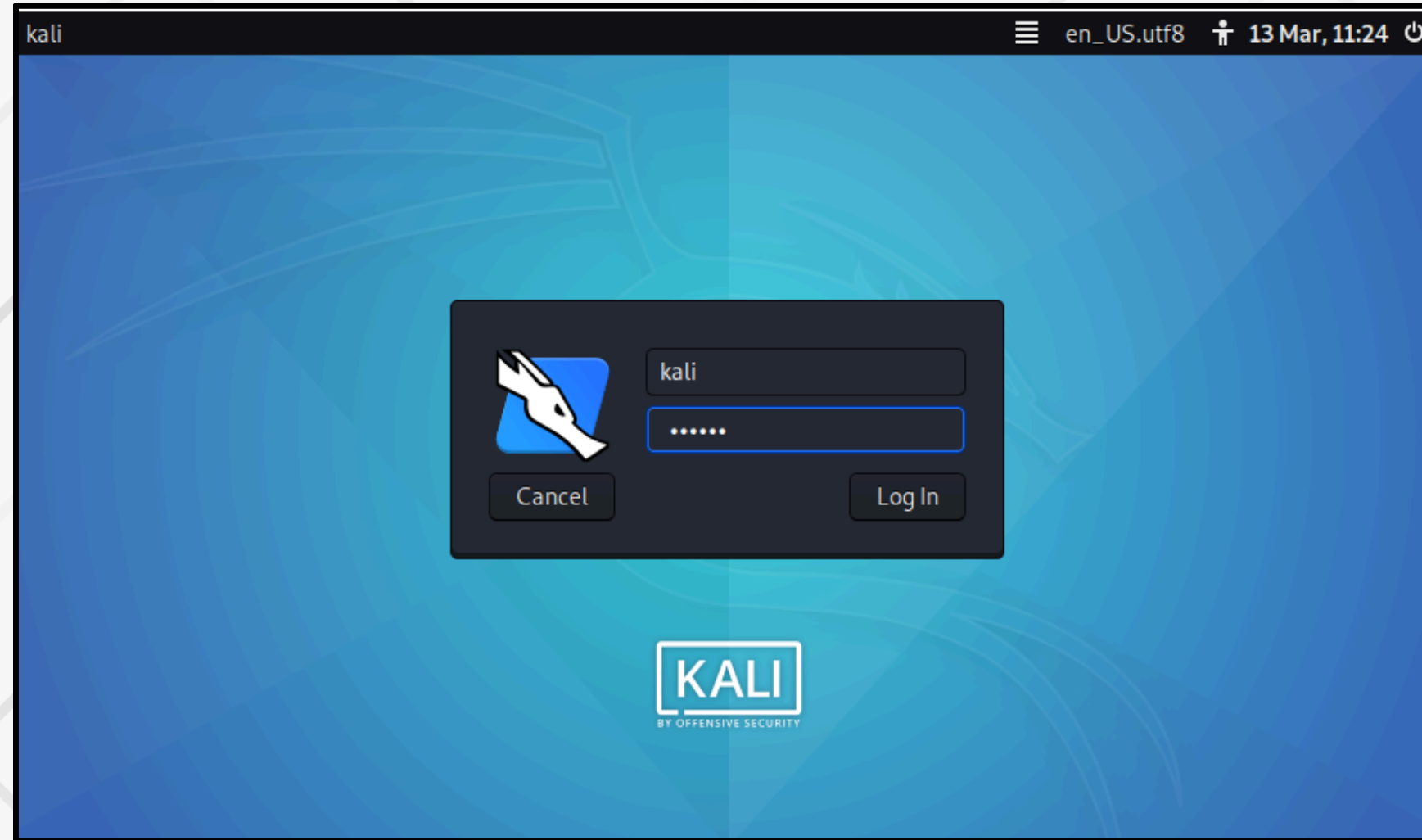
Just simply use the OS command to get the credentials

Scenario 1:



**Command and Control
Ingress Tool Transfer
(ID: T1105)**

Scenario 1:



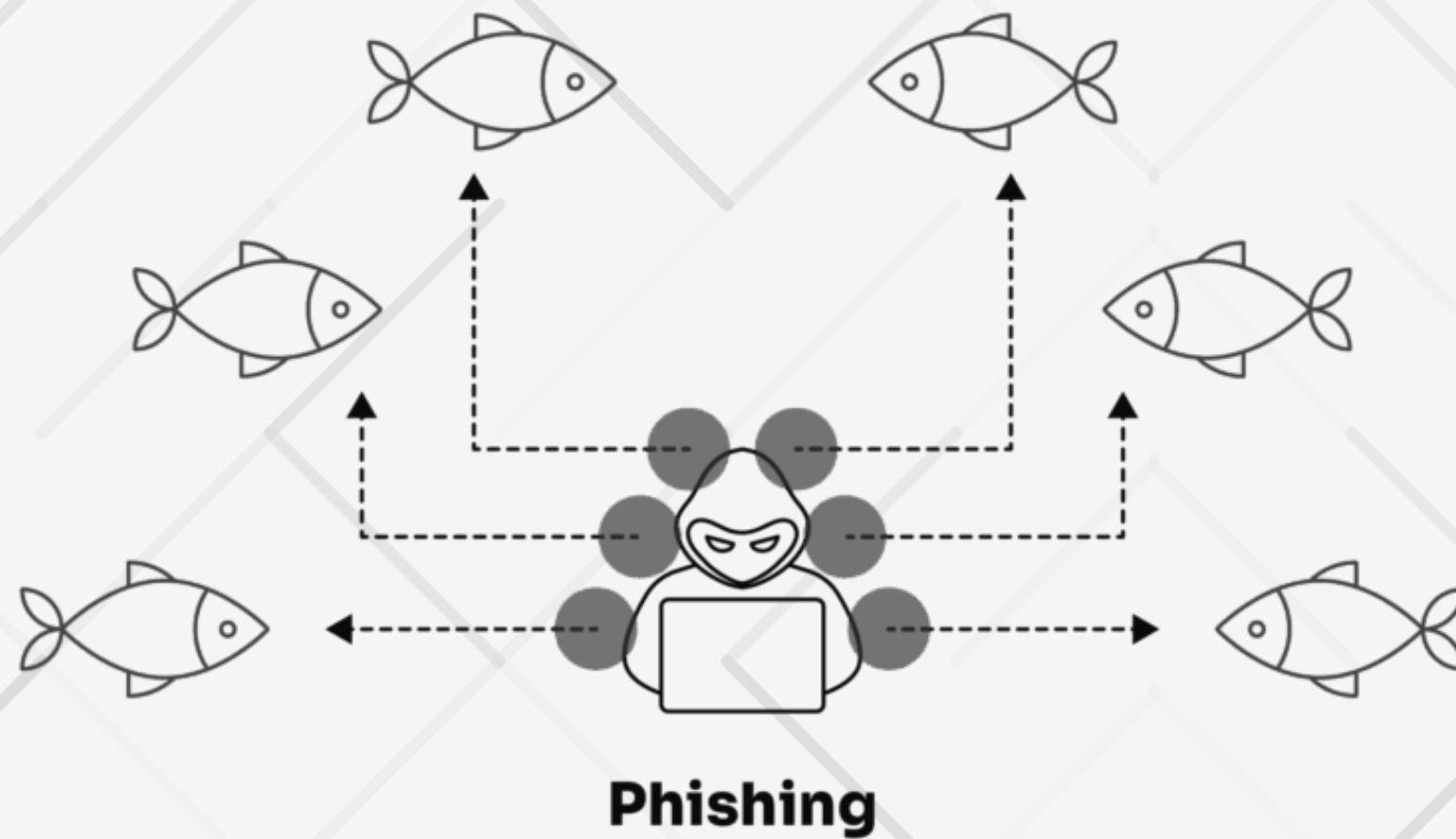
**Privilege Escalation
Valid Accounts
(ID: T1078.001)**



DEMO

Scenario 2:

Initial Access Spearphishing Attachment (ID: T1566.001)



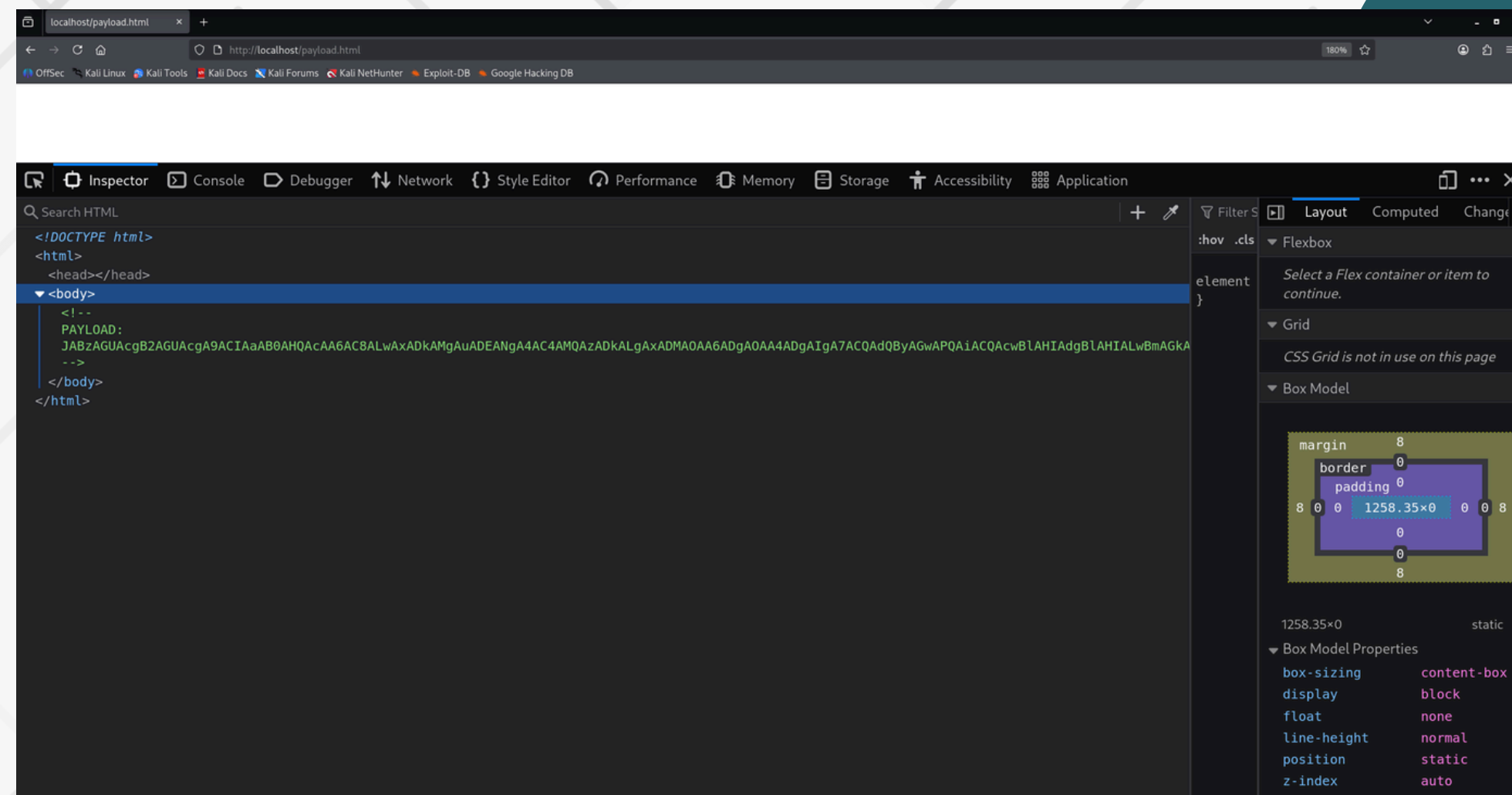
Scenario 2:

Execution
User Execution: Malicious File
(ID: T1204.002)



Scenario 2:

Defense Evasion Obfuscated Files or Information (ID: T1027)



Scenario 2:

**Defense Evasion
Hidden Window
(ID: T1564.003)**



**Execution
PowerShell
(ID: T1059.001)**

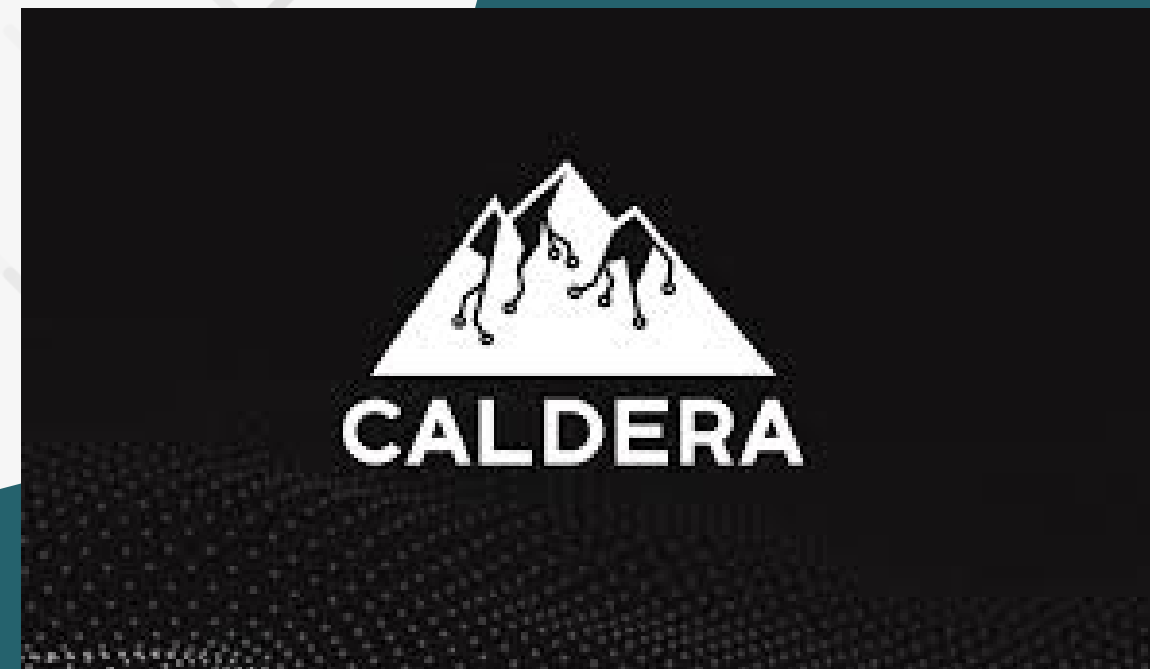


Scenario 2:

**Command and Control
Web Protocols
(ID: T1071.001)**

+

**Command and Control
Ingress Tool Transfer
(ID: T1105)**

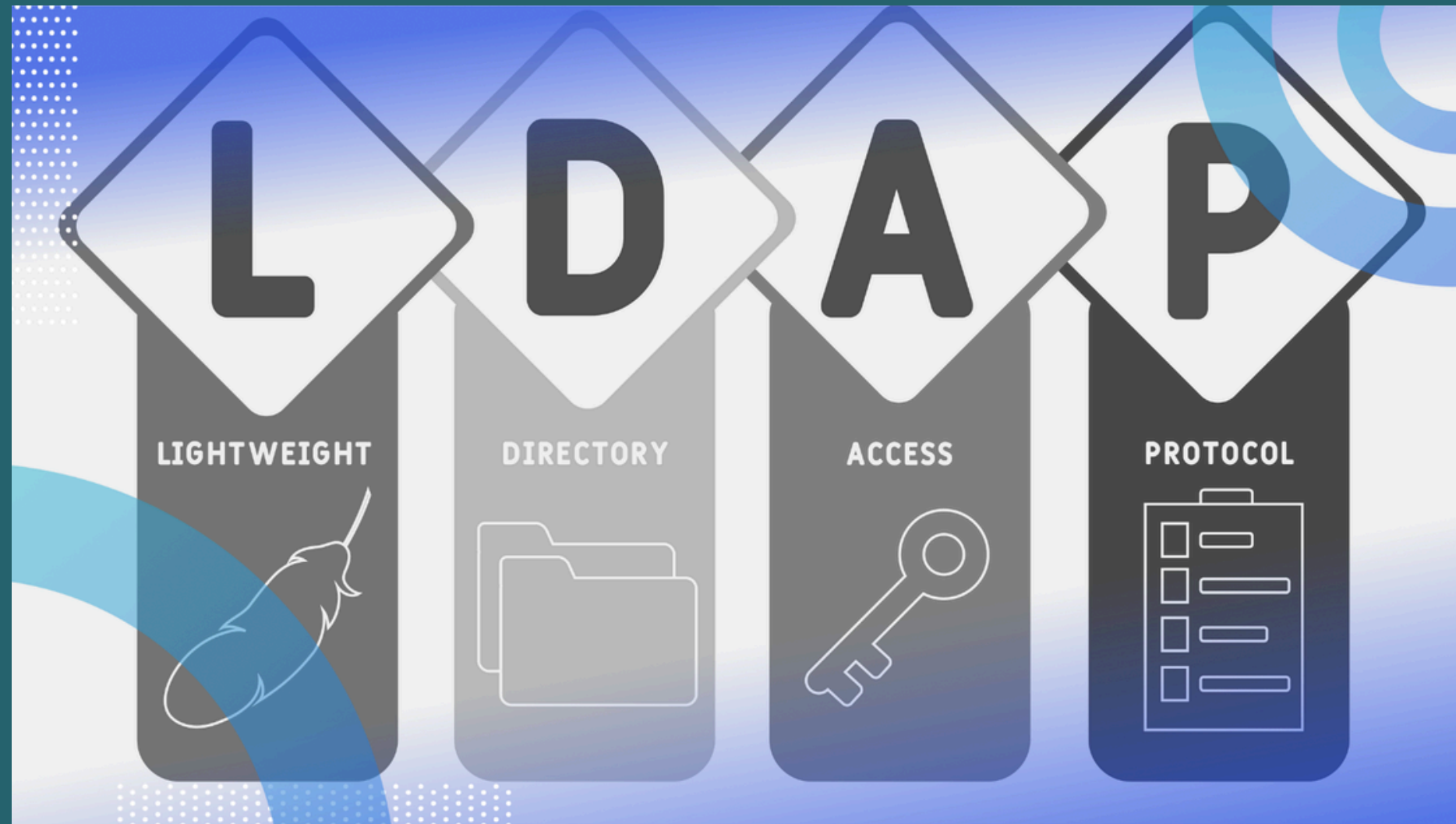




DEMO



Active Directory



LDAP



Kerberos

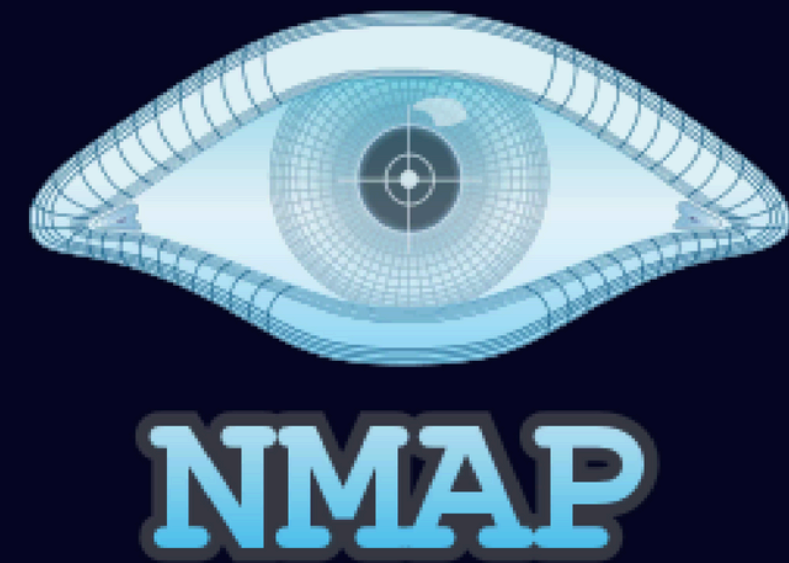
Scenario 3:

**Discovery
Remote System Discovery
(ID: T1018)**



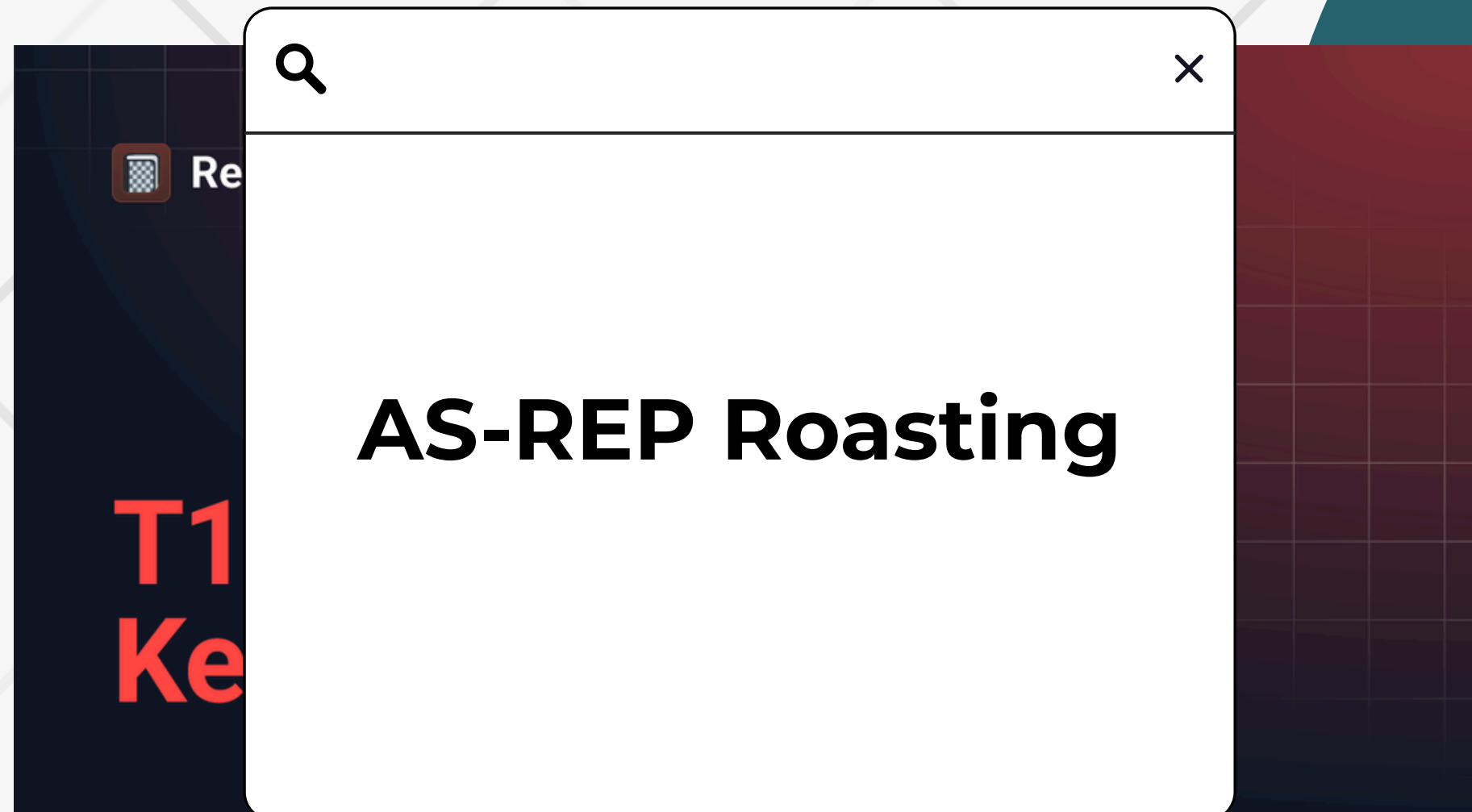
**Discovery
Network Service Discovery
(ID: T1046)**

```
C:\Windows\system32>nmap -sn 192.168.204.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-23 15:11 -0800
Nmap scan report for 192.168.204.1
Host is up (0.0021s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.204.128
Host is up (0.0050s latency).
MAC Address: 00:0C:29:26:F0:EA (VMware)
Nmap scan report for 192.168.204.130
Host is up (0.0050s latency).
MAC Address: 00:0C:29:29:41:BB (VMware)
Nmap scan report for 192.168.204.254
Host is up (0.0026s latency).
MAC Address: 00:50:56:E8:08:22 (VMware)
Nmap scan report for 192.168.204.132
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 13.58 seconds
```



Scenario 3:

Credential Access
Steal or Forge Kerberos Tickets:
AS-REP Roasting
(ID: T1558.004)





DEMO

Scenario 3:

Privilege Escalation
Valid Accounts: Domain
Accounts
(ID: T1078.004)

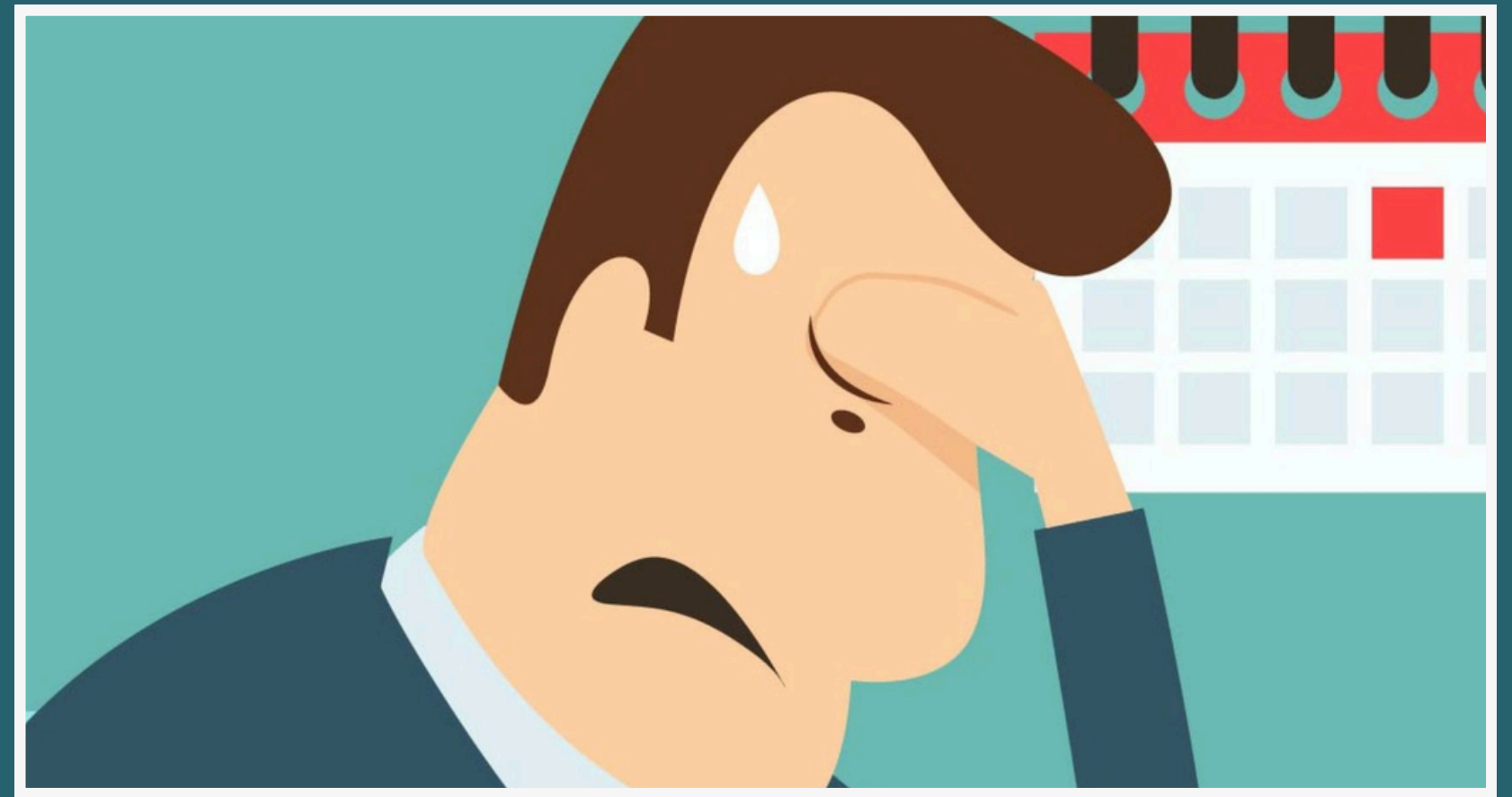


Lateral Movement
Remote Services
(Potential)
(ID: T1021)



Pain Points

- Idealized environments
- No real threats
- Lack of real system design/
defense mechanisms





FUTURE WORKS



Improving Attacks

Improve the attack, obfuscate the attack, adding the persistence for the attack after shutting down the victim machine



➤ More scenarios

IF POSSIBLE, there should also be a defense/ detection system to log and monitor the attack for more understanding, educational purposes.

But maybe there can be another way...



THANK
YOU
FOR
YOUR
PATIENCE

